M8

ISO/IEC 42001 and Governance Structure

Module 8 — A management system, who does what, and what gets written down

307307 — BI Methods for Generative AI

AI Governance · University of Petra

Lecturer: _____ Date: _____



AI Governance in Practice — Hemang Doshi (Packt, 2026)

The Hardest Part of Certification



Figure 5.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Auditors want proof

Having an AI risk policy is not enough. Show that AI systems are identified, risks assessed, controls working and results monitored.

Today: the standard, the governance structure, and the documents that provide evidence.

What You Will Be Able to Do

1. **Describe** the structure of ISO/IEC 42001: clauses, Annex A controls and the Statement of Applicability.
2. **Explain** the road to certification and what auditors look for.
3. **Choose** between OECD, NIST AI RMF and ISO/IEC 42001 for a given situation.
4. **Assign** governance roles with a RACI matrix and name the documents that a governance program needs.

ISO/IEC 42001 at a Glance

1 What it is

The first international management-system standard for AI (2023). It sets requirements for an AI Management System, or AIMS.

2 What an AIMS is

The policies, processes, roles, responsibilities and controls used to manage AI in a structured way.

3 Why it is useful

It uses the same structure as ISO/IEC 27001, so it fits with security, privacy and risk programs. You can be certified.

ISO and IEC are international standards bodies (ISO has members in more than 160 countries). Certification is for the standard as a whole: an organization cannot be certified on partial compliance.

The Ten Clauses

Clause	Title	In plain words
4	**Context of the organization**	Understand internal and external factors; define the scope of the AIMS
5	**Leadership**	Top management commitment, AI policy, roles and accountability
6	**Planning**	AI risk assessment, risk treatment and objectives
7	**Support**	Resources, competence, awareness, communication, documents
8	**Operation**	Operational controls across the AI lifecycle
9	**Performance evaluation**	Monitoring, measurement, internal audit, management review
10	**Improvement**	Corrective action and continual improvement

Based on Table 5.1 of the book.

Clauses 1–3

Scope, references and terms. Informational, not audited.

Clauses 4–10

are the mandatory requirements. They must all be implemented for certification.

Annex A Controls and the SoA

Annex A: ten control areas

1. Governance and accountability
2. AI risk management
3. Data governance
4. AI lifecycle management
5. Transparency and explainability
6. Human oversight
7. Security and resilience
8. Monitoring and logging
9. Incident management
10. Third-party AI

Annexes B to D: implementation guidance, mapping to other standards such as ISO/IEC 27001, and sector considerations.

Statement of Applicability (SoA)

For every Annex A control: does it apply, why, and how is it implemented? Auditors treat the SoA as key evidence.

Control area	Applies?	Reason and how
Human oversight	**Yes**	Admissions decisions affect people. A person reviews every decline.
Third-party AI	**Yes**	The chatbot is bought. Vendor assessed before contract.
Model training	**No**	We buy models and train none. Reason recorded.

Illustrative campus example, not from the book.

The Road to Certification

1

Write an AI governance policy

Set intent, principles and commitment, aligned with the standard.

2

Run a gap assessment

Compare what you do with the requirements. Assign fixes.

3

Prepare the SoA

Decide which Annex A controls apply, and record why.

4

Implement and keep evidence

Run the controls, monitor them and keep records.

5

Certification audit

An accredited body checks that it works in practice.

Case in the book: a lender that uses AI for loans. Its gap assessment found no AI-specific impact assessment, an incomplete AI inventory, weak checks for data quality and bias, limited explainability, and no defined human oversight or monitoring. Each gap was assigned to an owner.

What Auditors Look For

1 AI inventory

Systems in scope, with purpose, owner, data and risk class

2 Risk assessment and treatment

Risks found, plans made, owners named, controls in place

3 Roles and responsibilities

Assigned in writing. Staff can explain theirs when asked

4 Controls in operation

Data, oversight, transparency, security and third-party controls work

5 Monitoring and measurement

Regular results, risk indicators and review reports

6 Incidents and corrective action

Issues recorded, investigated, fixed and re-checked

7 Internal audit and management review

Both done on a schedule, with follow-up

8 Training and records

Competence shown; records kept under control

Based on Chapter 5 of the book.

Common Pitfalls

1 IT-only ownership

Business, legal, risk, privacy and security must take part

2 Chasing the certificate

Build governance that keeps working after the audit

3 Policies on paper

Controls must run and leave evidence

4 Incomplete inventory

You cannot govern AI you do not know about

5 SoA as a formality

Base it on real risks, with reasons for exclusions

6 Weak management support

Without leaders there is no authority or budget

7 Ignoring third-party AI

Vendor and cloud AI must be assessed too

8 A one-time project

It is a management system: monitor and improve

Based on Chapter 5 of the book.

Which Framework Should We Use?

Our situation	Good starting point	Why
Just starting with AI; no AI law applies yet	**OECD AI Principles**	Sets direction without heavy process
Ready for detailed policies, but want flexibility	**NIST AI RMF**	Four functions; you choose how to apply them
Need a formal, organization-wide, auditable system, maybe certified	**ISO/IEC 42001**	Management system with roles, controls, audit
We serve people in the EU	**EU AI Act**	It is law: first check whether it applies

Based on Chapter 11 of the book.

They work together. OECD says what good looks like, NIST says which risk activities to run, ISO says how to build them into the organization, and the law says what you must do. The book favors ISO for its auditability and fit with existing systems, while NIST and OECD are lighter to start with.

Build on ISO/IEC 27001 If You Have It

1. **Review the scope** — decide whether the same units, systems and locations belong in the AI scope. It need not be identical.
2. **Align risk management** — add AI risk criteria (fairness, transparency, safety, oversight) to the existing method and register.
3. **Align the committee** — widen the existing IT or security committee to cover AI risks, inventory and incidents.
4. **Align management review** — add AI risks, incidents and objectives to the existing review.
5. **Align internal audit** — extend the audit program and checklist to AI areas. Add AI expertise if needed.

ISO/IEC 42001 is not only an extension of ISO/IEC 27001: security and responsible AI have different goals. Based on Chapter 5.

Four Questions Governance Must Answer



Figure 12.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Build on existing governance and risk arrangements. Do not create a separate empire.

1. **Who owns the AI system?**
   A named AI system owner
2. **Who approves its use?**
   The committee; senior management for high risk
3. **Who monitors its behavior?**
   Owner and technical teams, with risk oversight
4. **Who is accountable when it goes wrong?**
   The owner, with a defined escalation path

Key Roles

1 Board and senior management

Set direction, approve policy, define risk appetite

2 AI governance committee

Review high-risk use cases and significant risks

3 AI GRC officer

Coordinates governance, keeps inventory and register. Not the system owner

4 AI system owner

Accountable for one system's purpose, risks and lifecycle

5 Business and AI development teams

Build and run systems; control data, bias and performance

6 IT and information security

Secure environment, access, logging, incident response

7 Risk and compliance

Second-line oversight; review high-risk use cases

8 Legal and privacy

Laws, contracts, data protection, intellectual property

9 Internal audit

Independent assurance. Never runs the AI systems

Based on Chapter 12 of the book. Small organizations may combine roles if independence and accountability are kept.

RACI: Who Does What

Activity	Board	AI committee	GRC officer	System owner	Dev team	Risk / compl.	Legal / privacy	Security	Audit
Approve AI governance policy	**A**	**R**	C	I	I	C	C	C	I
Maintain AI inventory	I	I	**R**	**A**	C	C	I	C	I
Conduct AI risk assessment	I	C	**R**	**A**	C	C	C	C	I
Regulatory and legal assessment	I	C	**R**	C	I	C	**A/R**	I	I
Approve high-risk AI system	**A**	**R**	C	C	C	C	C	C	I
Monitor AI system	I	C	C	**A**	**R**	C	C	**R**	I
Manage AI incidents	I	C	**R**	**A**	**R**	C	C	**R**	I
Independent governance audit	I	I	C	C	I	C	C	C	**A/R**

A selection of rows from Table 12.1 of the book.

R does the work · **A** owns the outcome · **C** is consulted · **I** is informed. Disagreements go to the committee or senior management.

Documents: From Intent to Evidence



Figure 13.2 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Level	Examples
Policy	AI governance policy
Procedures	Use-case approval, risk assessment, monitoring, incident handling, escalation
Guidelines	Good practice, applied with flexibility
Templates and checklists	Use-case form, impact and risk forms, vendor checklist
Records and evidence	Approvals, assessments, monitoring reports, incident records, committee minutes

Change management example: a model that only recommended loans now decides them. This change needs a new risk and impact assessment and approval.

What an AI Governance Policy Contains

1. Purpose and objectives
2. Scope and applicability
3. Governance principles
4. Roles and responsibilities
5. AI risk management
6. AI use-case governance
7. Data governance for AI
8. Model and system governance
9. Human oversight and accountability
10. Third-party and vendor governance
11. Security and resilience
12. Compliance and legal alignment
13. Incident management and response
14. Documentation and record keeping
15. Training and awareness
16. Monitoring, review and improvement
17. Exceptions and non-compliance
18. Approval, review and maintenance

The policy should cover internally built, bought and third-party AI, including generative AI tools. (Based on Figure 13.3 of the book.)

Key Takeaways

1. ISO/IEC 42001 is a certifiable management-system standard for AI: clauses 4–10, Annex A controls and the SoA.
2. Certification needs evidence that governance works in practice, not only documents.
3. OECD, NIST AI RMF, ISO/IEC 42001 and the law work together. First ask which laws apply.
4. A governance structure answers who owns, approves, monitors and is accountable. A RACI matrix makes it clear.
5. A hierarchy of documents turns policy into evidence. Build on existing GRC systems.

Discussion and Activity

Discuss

1. Should a small university seek ISO/IEC 42001 certification? What are the pros and cons?
2. Why must the AI GRC officer not be the owner of every AI system?
3. Which document would you write first, and why?

Activity

Set up AI governance at the University of Petra (a fictional case)

A. Judge the audit evidence

B. Statement of Applicability

C. Fill a RACI matrix

D. Start the AI inventory

E. Policy essentials

Groups of 3–4. Handout: Module8_ISO42001_Structure_activity.docx